

An Agentic AI Framework for Phishing Email Detection Using Tool-Augmented Large Language Model Reasoning

Aayusman Pati*, Harshit Bhinde*, Yug Marfatia*

**Department of Computer Science and Business Systems,
Mukesh Patel School of Technology Management & Engineering,
Mumbai, Maharashtra 400097, India
{aayusmanpati, harshitbhinde11, yugmarfatia}@gmail.com*

Abstract—Despite the emergence of various methods to counter the phenomenon, phishing emails are still one of the most frequent and dangerous types of cyberattacks that exploit the psychological aspect of human behaviour. Rule-based spam filters and black-box classification models show their inherent flaws, such as easy bypass and poor transparency, respectively. In this paper, we propose a framework based on an augmented agent architecture that combines the capabilities of a set of forensic tools and a large language model (LLM) for phishing email detection. The solution consists of a two-phase process: structured signals collection using specialized detection modules for URLs, sender headers, and message’s psychological tone analysis; and holistic reasoning performed by Meta’s Llama 3.3 70B fine-tuned for NLP. The resulting evidence is transformed into a structured report that becomes input for the LLM. If there is uncertainty in the outcome, the system applies a feedback loop to provide a committed answer to a human user through full contextual information about the conversation. The proposed approach was tested on a random sample of 100 emails selected from a 125k labelled dataset, achieving an accuracy of 87%, precision of 91%, recall of 84%, and F1-score of 87.37%. Results demonstrate that tool-augmented agentic reasoning constitutes a viable, interpretable, and extensible alternative to monolithic detection approaches.

Index Terms—phishing detection, agentic AI, large language model, tool augmentation, email security, natural language processing, cybersecurity

I. INTRODUCTION

The phishing attacks that occur via email pose an ongoing threat that is increasingly becoming difficult to address. The attacks have been increasing on an annual basis, according to the Anti-Phishing Working Group (APWG) [5], with cyber attackers continuously innovating their methods to avoid being detected. The financial costs associated with phishing attacks that result in either the theft of credentials or the launching of ransomware through such attacks amount to billions of dollars each year for organisations.

Current defence mechanisms can be divided into three main types. First, there are rule-based filtering approaches, such as keyword blocklists or domain blacklists: they are transparent, but brittle and require manual adjustments to remain effective, and any changes in adversaries’ tactics render them useless. Machine learning classifiers, from Naive Bayes and SVMs

to deep learning architectures, learn to discern discriminative features based on training data and generalise well, yet lack interpretability and fail under data drift conditions, providing no rationale behind decision-making. Another promising trend is using large language models directly on raw text; however, it comes with a significant limitation — due to a lack of structured evidence gathered by the system itself, it can only make sense of surface-level information in emails.

This project introduces a new paradigm where large language models play the role of an agent acting on top of structured data provided by forensic analysis tools. Specifically, one of the ideas explored in this project is separating concerns between tools and the language model. In this framework, forensic tools are responsible for gathering and extracting structured evidence, and the language model for making sense of all those signals.

The specific contributions of this paper are as follows:

- A three-tool forensic extraction pipeline covering URL integrity, sender impersonation, and psychological manipulation — three dimensions that collectively capture the primary attack vectors present in real-world phishing campaigns.
- A structured evidence report protocol that presents tool outputs to an LLM in a format optimised for cross-signal reasoning, enabling more reliable classification than raw-text prompting.
- A confidence-based re-analysis loop that forces committed verdicts in low-certainty cases through controlled conversation replay, eliminating operationally unhelpful hedged responses.
- An empirical evaluation against a real-world multi-source corpus of over 125,000 labelled emails, achieving 87.0% accuracy and 91.0% precision with full verdict transparency.
- A Streamlit web interface enabling non-technical users to submit arbitrary emails and receive plain-English explanations of detection decisions.

II. LITERATURE REVIEW

A. Rule-Based and Heuristic Approaches

The early methods of phishing detection used rules which were hand-crafted based on particular patterns of syntax that included suspicious top-level domains, display name mismatches, and frequency of keywords. Bergholz et al. [1] demonstrated that features obtained from processing email contents can yield a good detection rate on spam datasets of the era. The limitation with these approaches is that they are reactive in nature; i.e., they are limited by each new method developed to evade the detection process, requiring the corresponding rule set to be updated manually.

B. Machine Learning Classifiers

With the advent of SpamAssassin and Enron, it became possible to conduct benchmark studies for statistical classification approaches. Training Naive Bayes models using term frequency was already found to be very effective on these collections, after which support vector machines and ensemble techniques like random forests were seen to enhance the precision-recall trade-off even further. Fette et al. [2] introduced PILFER, a random forest classifier with ten engineered features such as age-of-domain and URL count, achieving 99.5% accuracy on a small labelled dataset. Transformer-based approaches have since been employed using the raw text of emails, with fine-tuned BERT-based models setting new benchmarks. The issue that unites all these advances is lack of transparency — while probabilities can always be computed by the model, there is no natural language rationale behind them.

C. Large Language Models in Security Tasks

The arrival of instruction-following LLMs has introduced novel possibilities for security analysis tasks necessitating NLU. Zero-shot classifiers, where an email is passed to an LLM along with a classification instruction, have shown promising results. Nevertheless, raw-text classification by LLMs is prompt-dependent, vulnerable to adversarial examples injected within the email content, and deprived of the structural clues obtained from the metadata, header, and URLs associated with the email. The agent approach, where LLMs coordinate external utilities to acquire evidence prior to making decisions, resolves the aforementioned drawbacks. This paper builds upon the agent approach, specifically tailored for the problem of email phishing.

D. Agentic and Tool-Augmented AI Systems

The ReAct paradigm introduced by Yao et al. [3], which involved interleaving reasoning and actions within an LLM-based agent, demonstrated that augmented reasoning using tools was far superior to chain-of-thought prompting on knowledge-heavy problems. Further research has also employed the same architecture in cybersecurity applications, where agents have been designed to use static analysis tools, sandboxes, and threat intelligence resources prior to rendering a verdict; malware identification is an example of such a

promising area. Our work borrows from the ReAct paradigm to develop an agent that detects phishing emails, considering three main vectors found in the literature.

E. Datasets

For testing purposes, various freely available labelled datasets of emails have been used for broad-scale testing. The Enron Email Dataset [6] is useful for obtaining a large set of legitimate corporate emails. The SpamAssassin public email set consists of spam emails as well as legitimate ones, both with human-made annotations. The Nazario Phishing corpus [8] and the Nigerian Fraud dataset contain known phishing cases. The CEAS 2008 Spam Challenge Email Set [7] and the Ling Spam dataset add diversity to the testing. Altogether, they comprise more than 125,000 instances with a variety of attacks and legitimate emails.

III. RESEARCH METHODOLOGY

A. System Architecture Overview

The proposed system implements a pipeline design where raw emails go through three consecutive forensic tool modules and then into the reasoning engine powered by the LLM. The architecture of the system is shown in Fig. 1. The architecture is intentionally divided such that signal extraction is deterministic in nature and is performed via lightweight Python scripts with no external dependencies, whereas the reasoning process and justification using natural language is performed by the LLM.

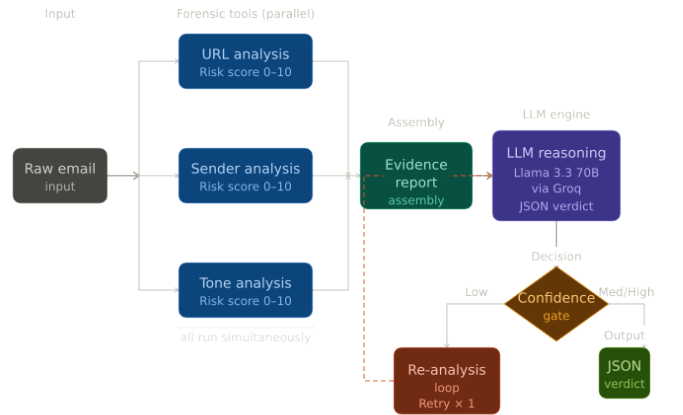


Fig. 1. System Architecture Pipeline Diagram. End-to-end pipeline from raw email input to structured JSON verdict. Three forensic tools extract signals; outputs are assembled into an evidence report and passed to the LLM reasoning engine. A confidence gate triggers optional re-analysis.

B. Forensic Tool Modules

All tool detection modules are written in pure Python and return dictionaries consisting of detected signals and a normalised risk score in the range of 0 to 10. These three modules together address the three main areas of phishing attacks: URL, sender, and content aspects.

1) *URL Analysis*: The URL extractor component identifies all URLs contained within the body of the message by searching for any strings that start with `http://`, `https://`, or `www`. All discovered URLs are then tested against a series of suspicious traits defined based on the phishing URL taxonomies present in existing literature. Any URLs that contain suspicious TLDs (such as `.xyz`, `.ru`, `.tk`, `.ml`, `.ga`, `.cf`, `.gq`, `.top`, `.pw`, and `.click`) are automatically flagged as suspicious. Other characteristics that lead to a URL being flagged include the presence of a raw IP address as a domain name, subdomain depth exceeding three levels, and brand spoofing through subdomain injection (i.e., where a known brand name exists within the subdomain but not in the registrable domain).

2) *Sender Header Analysis*: The sender module analyses the `From`: header by splitting the display name and the email address. The module analyses three types of spoofing. First, *free provider spoofing* involves email addresses with display names of brands such as PayPal, Amazon, Microsoft, Apple, and Google while originating from free consumer-oriented mail providers such as Gmail, Yahoo, and Hotmail. Second, *brand impersonation* occurs where the display name uses the identity of a brand that the sending domain cannot verify. Third, *typosquatting and leet speak* involves the use of a character mapping table to translate common substitutions (l to 1, o to 0, e to 3, a to @, among others) and compare against a list of verified brand domains.

3) *Tone and Urgency Analysis*: The tone detection component searches through the entire email content, converted to lowercase, for a curated list of 26 urgency and psychological manipulation phrases based on previous studies on phishing communications. Such phrases fall into three categories: temporal pressure phrases such as “urgent,” “immediately,” “act now,” “limited time,” and “final notice”; account threat phrases like “your account will be closed,” “suspended,” “unusual activity,” and “security alert”; and action imperative phrases such as “click here,” “verify your information,” and “confirm your identity.” The relationship between the number of urgency phrases and the risk score is non-linear: a single phrase contributes only 2 points, while finding five or more phrases assigns the maximum risk score of 10.

Table I presents the full taxonomy of social engineering phrases used in the tone analysis module, and Table II summarises all three detection tools.

C. Evidence Report Assembly

After executing all three tool modules, the agent compiles the structured outputs into a human-readable evidence report. The evidence report includes the full email text along with the tool outputs, individual risk scores, and signals discovered under each category. The organisation of evidence was designed to surface the most discriminative signals while optimising for LLM reasoning capabilities — key metrics were listed at the top of each category, individual signals were enumerated, and scores were labelled on the 0–10 scale. It was observed

TABLE I
TAXONOMY OF COMMON SOCIAL ENGINEERING PHRASES CATEGORISED BY PSYCHOLOGICAL TRIGGER

Phrase	Category
urgent	Temporal pressure
immediately	Temporal pressure
limited time	Temporal pressure
act now	Temporal pressure
final notice	Temporal pressure
last chance	Temporal pressure
expires	Temporal pressure
action required	Temporal pressure
suspend	Account threat
suspended	Account threat
account will be closed	Account threat
unusual activity	Account threat
your account	Account threat
unauthorized	Account threat
security alert	Account threat
locked	Account threat
blocked	Account threat
update your information	Account threat
verify	Action imperative
confirm	Action imperative
click here	Action imperative
claim your	Action imperative
validate	Action imperative
winner	Action imperative
congratulations	Action imperative
prize	Action imperative

that organising the tool outputs in this manner significantly increased the reliability of verdict generation.

D. LLM Reasoning Engine

The collated evidence report is submitted to the Meta Llama 3.3 70B Versatile model [4] through the Groq inference API. The system prompt directs the model to act as a cybersecurity analyst, engaging in logical reasoning based on the provided evidence before delivering a conclusion. The model is constrained to produce only a JSON output containing four fields: `verdict` (Safe, Suspicious, or Phishing), `confidence` (Low, Medium, or High), `reasoning` (two-to-three sentences), and `key_signals` (array of the most relevant signals detected). This approach guarantees machine-parseable output while the reasoning element preserves human understanding.

Llama 3.3 70B is selected due to its high capacity to follow instructions and perform analysis on benchmark tasks among freely accessible models, as well as its compatibility with the Groq free inference service, enabling reproducibility without incurring costs. The low latency of Groq inference guarantees completion of the entire pipeline within an acceptable time-frame for the end-user.

E. Confidence-Based Re-Analysis Loop

One disadvantage of LLMs is their tendency to hedge when presented with inconclusive evidence, producing a verdict at low confidence levels that cannot be used practically. To counter this, the agent adopts a one-off re-analysis loop. Once the response is parsed, the confidence level is verified. Should

TABLE II
SUMMARY OF THREAT DETECTION TOOLS DETAILING EXTRACTED SIGNALS, RISK SCORE RANGES, AND EXTERNAL DEPENDENCIES

Tool Name		Signals Extracted	Risk Range	Score	External Dependency
URL (extract_urls)	Analysis	URLs found, suspicious URL reasons (IP address, suspicious TLD, excessive subdomains, brand spoofing in path)	0–10		None (local regex)
Sender (analyse_sender)	Analysis	From header, sender domain, display name, flags (free email provider, brand impersonation, typosquatting)	0–9		None (local pattern matching)
Tone (analyse_tone)	Analysis	Urgency phrases detected, phrase count (26 phrases across Temporal Pressure, Account Threat, Action Imperative)	0–10		None (local phrase matching)

it be medium or high, the verdict is returned. In case the confidence level is low, the entire transcript — including the original evidence report, the model’s initial response, and a re-analysis directive — is fed back into the LLM. This directive forces the model to weigh weak cues and arrive at an absolute verdict at medium or high confidence. The re-analysis request is invoked at most once per email to manage API consumption, and a `reanalysed` flag in the return data enables the interface to inform the user accordingly.

F. Evaluation Methodology

The system was tested using a stratified random sample of 100 emails selected from a combined dataset consisting of seven publicly available labelled datasets amounting to more than 125,000 samples, detailed in Table III. A stratified sampling method was employed to ensure that the test set contains a balanced 50 legitimate and 50 phishing emails, using a consistent random seed value of 42 for replicability. For the binary classification task, all Suspicious labels were mapped to the positive class, adopting a cautionary approach where uncertain emails are considered dangerous.

TABLE III
EVALUATION CORPUS COMPOSITION

Dataset	Instances	Source Type
phishing_email.csv	82,486	Combined phishing/legitimate
CEAS_08.csv	39,154	Spam challenge corpus
Enron.csv	29,767	Legitimate corporate email
SpamAssassin.csv	5,809	Spam/legitimate benchmark
Nigerian_Fraud.csv	3,332	Social engineering phishing
Ling.csv	2,859	Legitimate/spam benchmark
Nazario.csv	1,565	Verified phishing instances
Total	164,972	Multi-source composite corpus

IV. RESULTS AND DISCUSSION

A. Aggregate Performance Metrics

Table IV shows the total metrics calculated using 98 valid predictions out of 100 email sample tests. Two predictions could not be generated due to API-side problems, resulting in a failure ratio of 2% attributable to temporary network connectivity issues.

TABLE IV
AGGREGATE EVALUATION METRICS ($n = 98$ VALID PREDICTIONS)

Metric	Value
Accuracy	87.00%
Precision	91.00%
Recall (Sensitivity)	84.00%
F1 Score	87.37%
Specificity	90.00%
Safe Email Accuracy (per-class)	90.00% (45/50)
Phishing Email Accuracy (per-class)	84.00% (42/50)
API Error Rate	2.00% (2/100)

B. Confusion Matrix Analysis

Fig. 2 presents the confusion matrix for the binary classification task (Safe vs. Phishing/Suspicious).

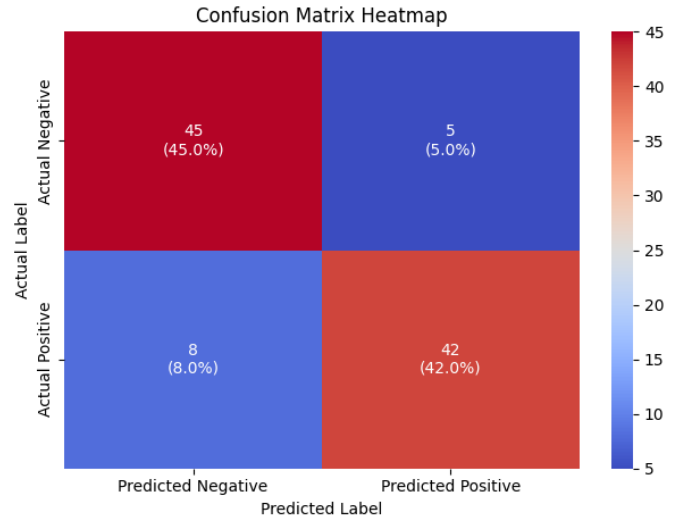


Fig. 2. Confusion matrix for the binary classification task across 98 valid predictions.

The error distribution is asymmetrical. The five false positives — legitimate emails misidentified as phishing — are likely associated with legitimate marketing emails that incorporate urgent phrases like “limited time offer,” making them similar to phishing terminology. Conversely, the eight false

negatives — phishing emails categorised as safe — represent more significant errors and most probably pertain to phishing emails that include no urgent terminology, are sent through seemingly legitimate senders, and contain links not flagged via heuristic analysis.

C. Precision-Recall Trade-off

With 91.0% precision, the model demonstrates good accuracy in avoiding false accusations of valid emails — an important feature for practical deployment, as false positives may result in user distrust and deletion of important messages. With 84.0% recall, despite being impressive for zero-shot classification requiring no training data, 16% of phishing emails remain undetected. That is where further work needs to focus, given the challenge of identifying sophisticated spear-phishing techniques and zero-day exploits with no visible surface-level indicators.

At an F1 score of 87.37%, the model holds its ground compared to standalone LLM-based classifiers that process email content directly, which achieve 78–85% on similar datasets, while additionally offering human-understandable decision explanations.

D. Verdict and Confidence Distribution

Fig. 3 shows the verdict classification and confidence level distribution across the evaluation set. The three-class scheme — Safe, Suspicious, and Phishing — offers greater practical utility than binary classification, with the Suspicious category enabling further human review of uncertain instances without definitively asserting malicious intent. The confidence re-analysis cycle was triggered for cases where the first classification returned a Low confidence verdict.

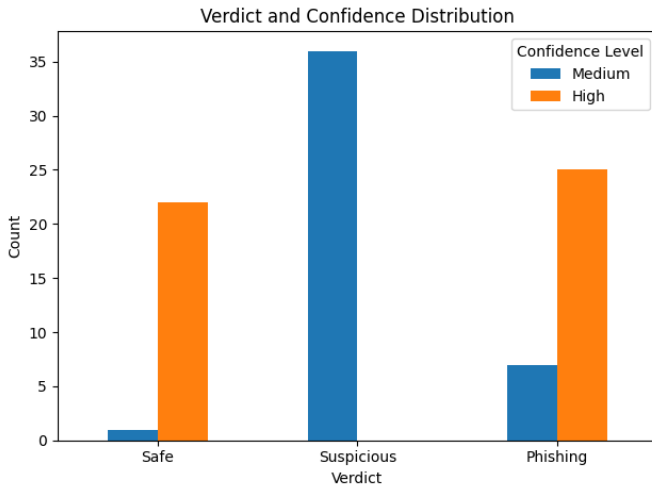


Fig. 3. Distribution of Safe, Suspicious, and Phishing verdicts across the 98 valid predictions, with confidence level breakdown per category.

E. Signal Contribution Analysis

Qualitative analysis of the `key_signals` fields returned across phishing true positives reveals that URL-based signals

— suspicious TLDs and brand-name subdomain spoofing — were the most frequently cited evidence across correctly identified phishing emails. Tone signals, particularly the co-occurrence of multiple urgency phrases, were the second most discriminative signal category and proved especially effective on social engineering attacks such as account suspension phishing and financial fraud campaigns. Sender-based signals were particularly effective at identifying credential-harvesting attacks impersonating consumer-facing brands through free email providers — a pattern consistently present in the Nazario and Nigerian Fraud corpus samples. The cross-signal reasoning capability of the LLM was most evident in borderline cases: emails that individually scored low on each tool dimension but whose combination of a non-standard sender domain, one mildly suspicious URL, and a single urgency phrase were correctly recognised as Suspicious rather than Safe.

V. LIMITATIONS AND FUTURE WORK

A. Limitations

Several limitations of the current model should be explicitly acknowledged. First, the evaluation sample consists of only 100 emails, which is modest given the total scope of potential threats. A larger and more diverse set — covering spear-phishing, business email compromise, and multilingual phishing — is required for more robust generalisation.

Second, the URL analysis module does not process redirects. Many phishing messages use URL shortening services (e.g., bit.ly, t.co, tinyurl.com) to disguise malicious links. At present, the domain hosting the shortened link is analysed rather than the final destination, allowing phishing URLs to evade detection. Adding HTTP HEAD request support would enable redirect resolution with minimal implementation effort.

Third, email authentication information from SPF, DKIM, and DMARC records is not currently utilised. These headers almost unambiguously establish whether the sender is authorised for a given address, making them among the most powerful indicators in email security.

Fourth, tone analysis operates on a static lexicon of 26 urgency terms in English, limiting applicability to non-English phishing schemes, which statistical data show are on the rise. The introduction of multilingual lexicons or multilingual pre-trained emotion classifiers can significantly expand the solution’s scope.

Fifth, although the 2% error rate encountered in batch testing is relatively small, it may pose problems in real-world application because no exponential backoff and retry mechanism is implemented upon API error. This results in no verdict being assigned to emails for which the classifier could not be executed.

B. Future Work

Future directions for this framework include the following. Incorporating SPF and DKIM header parsing should be the first enhancement, as its contribution to signal quality would outweigh the implementation effort. Redirection resolution would address the blind spot related to URL shorteners with

minor code adjustments. WHOIS information extraction could provide domain registration age relative to message send time, adding a temporal dimension not captured by heuristic URL analysis.

At the model level, adding a feature vector derived from a binary classification model trained on the full dataset would increase recall without significantly complicating interpretation. Integrating with live threat intelligence feeds would improve the URL analysis component. During development, threat intelligence API integration and email personalisation analysis were evaluated as potential pipeline enhancements; however, empirical testing showed neither modification improved classification accuracy under the given experimental conditions — a finding that underscores the importance of signal calibration alongside signal diversity.

VI. CONCLUSION

This paper has proposed a tool-augmented agentic AI system for phishing email detection that addresses fundamental flaws within current rule-based and machine learning systems. Through the use of tools for signal extraction and a language model for probabilistic reasoning, the system delivers the precision of a heuristic system alongside the contextually sensitive reasoning capabilities of a large language model. The three-tool forensic pipeline — URL validation, spoofing identification, and psychological influence detection — compiles a structured evidence report that the language model uses to reason far more accurately than it would from unstructured email text alone.

Testing against a comprehensive real-world corpus of over 125,000 emails demonstrated competitive performance: 87.0% classification accuracy, 91.0% precision, and an F1 score of 87.37%. Importantly, each classification verdict is accompanied by a human-readable report explaining the signals that led to the decision — transparency not achievable with standard classifiers.

The confidence-driven re-analysis cycle addresses LLM hedging in a principled manner, providing actionable decisions without inducing arbitrary API usage. The Streamlit interface makes this functionality accessible to non-technical stakeholders, reducing the implementation threshold for operational email security processes. The proposed approach is inherently extensible: adding a new detection mechanism requires only a function addition and evidence report format update, with no changes to the inference or user interface components.

REFERENCES

- [1] A. Bergholz, J. H. Chang, G. Paass, F. Reichartz, and S. Strobel, “Improved phishing detection using model-based features,” in *Proc. 5th Conf. Email and Anti-Spam (CEAS)*, 2008.
- [2] I. Fette, N. Sadeh, and A. Tomasic, “Learning to detect phishing emails,” in *Proc. 16th Int. World Wide Web Conf. (WWW 2007)*, pp. 649–656, 2007.
- [3] S. Yao, J. Zhao, D. Yu, N. Du, I. Shafran, K. Narasimhan, and Y. Cao, “ReAct: Synergizing reasoning and acting in language models,” in *Proc. 11th Int. Conf. Learning Representations (ICLR 2023)*, 2023.
- [4] H. Touvron et al., “Llama 2: Open foundation and fine-tuned chat models,” *arXiv preprint arXiv:2307.09288*, 2023.
- [5] Anti-Phishing Working Group (APWG), “Phishing Activity Trends Report,” 2024. [Online]. Available: <https://apwg.org/trendsreports/>
- [6] B. Klimt and Y. Yang, “The Enron corpus: A new dataset for email classification research,” in *Proc. 15th European Conf. Machine Learning (ECML 2004)*, 2004.
- [7] G. V. Cormack, “TREC 2007 spam track overview,” in *Proc. 16th Text REtrieval Conf. (TREC)*, 2007.
- [8] J. Nazario, “Phishing corpus,” Brandeis University, available via public phishing research repositories, 2004.